

E-ariary

Vulnérabilité : Absence de protection contre le Clickjacking

Détails : L'en-tête de réponse X-Frame-Options ou la directive CSP frame-ancestors sont absents.

Recommandations : Configurer le serveur Apache pour envoyer l'en-tête X-Frame-Options : SAMEORIGIN ou ajouter frame-ancestors 'self' à la directive Content-Security-Policy.

PoC :

```
GET /assets/pages/or/banner-or.html HTTP/2
Host: preprod.banky-foibe.mg
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:141.0) Gecko/20100101 Firefox/141.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: fr,fr-FR;q=0.8,en-US;q=0.5,en;q=0.3
Accept-Encoding: gzip, deflate
Referer: https://preprod.banky-foibe.mg/eariary
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: iframe
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Priority: u=4
Te: trailers
```

Vulnérabilité : Politique de Sécurité de Contenu (CSP) incomplète

Détails : La directive actuelle upgrade-insecure-requests est insuffisante. L'absence de restrictions sur les sources de scripts (script-src) et de styles (style-src) facilite l'injection de contenus malveillants.

Recommandations : Implémenter une CSP stricte. Autoriser uniquement les domaines de confiance et interdire unsafe-inline si possible.

PoC : Défaut de configuration

```
HTTP/2 200 OK
Date: Tue, 10 Mar 2026 04:05:26 GMT
Content-Type: text/html; charset=UTF-8
Content-Length: 3734
Server: Apache
Last-Modified: Mon, 09 Mar 2026 17:43:38 GMT
Etag: "e96-64c9af165d027-gzip"
Accept-Ranges: bytes
Vary: Accept-Encoding
Content-Security-Policy: upgrade-insecure-requests
```

Vulnérabilité : Injection de paramètre (Client-side URL Injection)

Détails : Dans la fonction getAutreTaux(date), la variable date est concaténée directement à l'URL de l'API sans aucun nettoyage ou encodage. Un attaquant capable de contrôler l'entrée date pourrait manipuler la requête vers l'API, potentiellement pour accéder à d'autres endpoints ou exfiltrer des données via des techniques d'injection de paramètres.

Recommandations : Utiliser encodeURIComponent(date) ou, de préférence, l'objet URLSearchParams pour construire les requêtes de manière sécurisée.

PoC :

```
async function getAutreTaux(date) {
  const url =
    'https://www.banky-foibe.mg/admin/wp-json/bfm/autres_
    _taux_pomi_by_date?date=' + date;
  let items = [];
  try {
    const response = await fetch(url);
    if (!response.ok) {
      throw new Error("Network response was not ok");
    }
  }
```